HUNT-SAGE · THREAT HUNTING CHEAT SHEET

Active Directory Attacks → Artefacts

A quick map from AD attack technique to what it looks like in logs and how to hunt it.

github.com/iamjammie/hunt-sage · iamjammie.github.io/hunt-sage · Built 2026-10-31

Attack	How it works	Telemetry	Hunt signal	ATT&CK
LDAP/AD recon (BloodHound/SharpHound, ADFind, PowerView)	Bulk LDAP queries; SMB session/local-admin enumeration	DC LDAP query logs (event 1644 with diagnostic logging), Defender for Identity, network flow	One host querying thousands of objects; `(servicePrincipalName=*)`, `(objectClass=*)`; connections to many hosts on 445	T1087.002, T1069.002, T1482
Password spray	One/few passwords against many accounts	4625 / 4771 / 4776, Entra sign-ins	Many users, one source, few tries each	T1110.003
Kerberoasting	Request TGS for SPNs; crack offline	4769 (RC4 `0x17`)	Burst of distinct SPNs by one account	T1558.003
AS-REP roasting	Request AS-REP for no-preauth users	4768 PreAuthType 0, RC4	Requests for exposed accounts	T1558.004
NTLM relay (Responder, ntlmrelayx)	Poison LLMNR/NBT-NS/mDNS/WPAD; relay auth to SMB/LDAP/ADCS	4624 type 3 from unexpected source; LDAP signing events 2889; Zeek `ntlm.log`	Auth where source IP ≠ workstation name; machine accounts authenticating from non-owner IPs	T1557.001
Pass-the-hash	NTLM hash used directly	4624 type 3 NTLM, KeyLength 0; type 9	New source authenticating as admin without interactive logon	T1550.002
Pass-the-ticket / overpass-the-hash	Reuse or request tickets with stolen keys/tickets	4768 RC4 for AES users; 4769 with no 4768	TGS without TGT from same host; abnormal lifetimes	T1550.003
Golden ticket	Forged TGT with `krbtgt` key	4769/4624 for accounts with no 4768; ticket lifetime > policy; SIDHistory oddities	Service tickets for users that never authenticated; RC4 where AES expected	T1558.001
Silver ticket	Forged TGS with service key	Service logons (4624) with no corresponding 4769 on a DC	Missing DC ticket events for service access	T1558.002
DCSync	Replicate secrets via DRSUAPI	4662 replication GUIDs; Zeek `dce_rpc` `DRSGetNCChanges`	Non-DC source	T1003.006
NTDS.dit theft	VSS/ntdsutil/diskshadow copy	4688/Sysmon 1 (`ntdsutil ifm`, `vssadmin create shadow`), Sysmon 9, file creation of `ntds.dit`	Copy of ntds.dit + SYSTEM hive outside backups	T1003.003
DCShadow	Rogue DC registers and pushes changes	4928/4929, 5137 (nTDSDA/server object creation), unusual replication	New "DC" objects in Configuration NC from non-DCs	T1207
GPO abuse	Modify GPO to deploy tasks/scripts	5136 on `groupPolicyContainer`; SYSVOL file changes	Edits by non-GPO admins; new immediate scheduled tasks	T1484.001
ACL / delegation abuse	GenericAll/WriteDACL/DCSync rights, RBCD	5136, 4670, `msDS-AllowedToActOnBehalfOfOtherIdentity` changes	ACL changes on privileged objects, AdminSDHolder	T1098, T1222.001
Unconstrained / constrained delegation abuse	Capture or abuse forwarded TGTs	4769/4624 patterns, `TrustedForDelegation` flag changes (4738)	Servers with delegation receiving admin tickets	T1558
AD CS abuse (ESC1-ESC8)	Misconfigured templates / enrollment to get certs as privileged users	CA events 4886/4887 (request/issue), 4898, template change events; Kerberos PKINIT (4768 with cert info)	SAN specifying other users; certs for DA from non-DA hosts	T1649

Attack	How it works	Telemetry	Hunt signal	ATT&CK
Shadow credentials	Write `msDS-KeyCredentialLink` then PKINIT	5136 on that attribute	Key credential writes by non-sync accounts	T1556
Machine account quota abuse / noPac / sAMAccountName spoofing	Create machine account, rename	4741, 4742, 4781 rename	Machine account created by standard user then renamed to a DC name	T1136.002
Zerologon / Netlogon abuse	Exploit Netlogon cryptographic flaw	5827-5829, 4742 password reset of DC account	Non-DC machine account auth anomalies	T1210
AdminSDHolder / SIDHistory persistence	Hidden privilege via ACL / SID injection	5136 on AdminSDHolder, 4765/4766 SID history	Unexpected SID history	T1134.005, T1098
Skeleton key / LSASS patch	In-memory patch on DC	Sysmon 10 on lsass from non-system, driver load, new `mimidrv`	Auth with master password; LSASS tampering	T1556.001
Trust abuse (SID filtering gaps)	Cross-domain/forest escalation	4768/4769 across trust, 4675 SIDs filtered	Tickets with extra SIDs	T1134.005

Default auditing checklist for DCs

- Account Logon: Kerberos Authentication Service, Kerberos Service Ticket Operations, Credential Validation
- Logon/Logoff: Logon, Special Logon
- DS Access: Directory Service Access, Directory Service Changes
- Account Management: User/Computer/Security Group management
- Detailed Tracking: Process Creation (+ command line)
- Policy Change: Audit Policy Change, Authentication Policy Change
- System: Security System Extension (4697), Security State Change
- Enable **LDAP diagnostic logging** (1644) temporarily for recon hunts; **NTLM auditing** (`Restrict NTLM: Audit...`) for relay/PtH hunts

Defensive tools to add context

- **BloodHound / PingCastle / Purple Knight**: find the attack paths and misconfigurations that attackers will use
- **Microsoft Defender for Identity**: sensor-based detections of many techniques above
- **Honeytokens**: fake admin account, fake SPN, canary share
- Detailed playbooks: Kerberoasting, DCSync, LSASS, Lateral movement

HUNT-SAGE
iamjammie/hunt-sage